

Федеральное государственное автономное образовательное учреждение
высшего образования «Национальный исследовательский университет
ИТМО»

Отчёт
по лабораторной работе №7
по дисциплине
«Информационная безопасность»

Выполнил:
студент 4-го курса
Батманов Даниил Евгеньевич
Группа:
Р3407

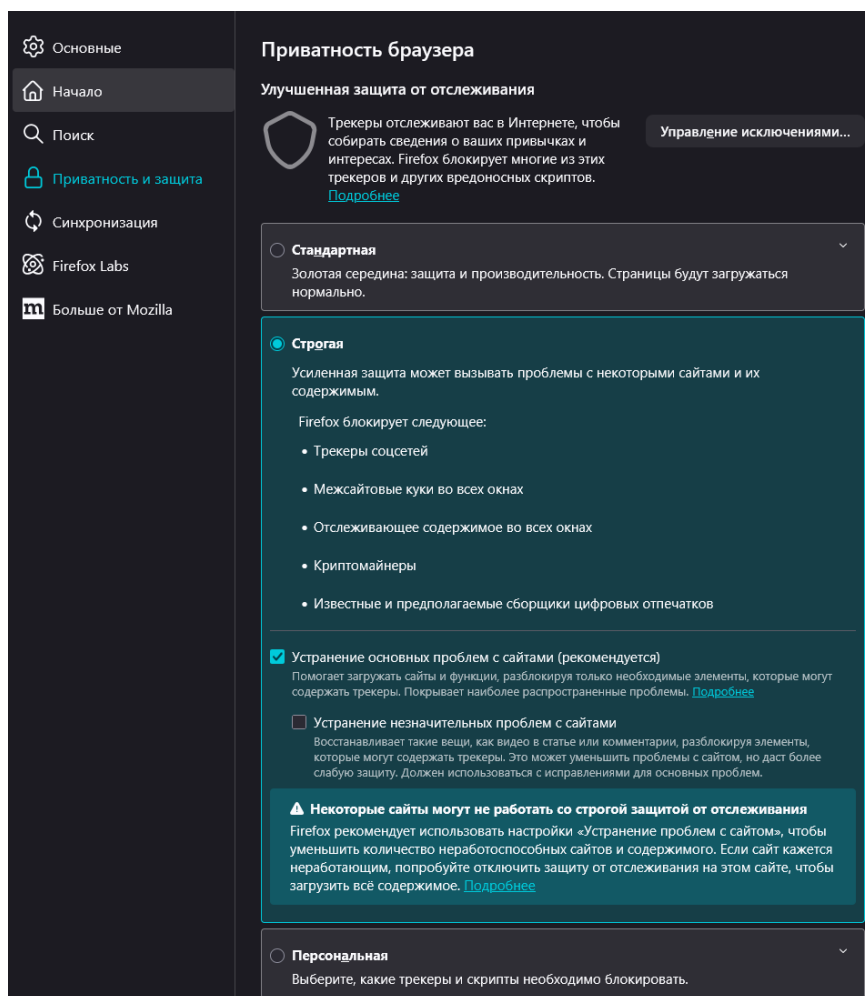
г. Санкт-Петербург, 2025

Настройка безопасности браузера (Mozilla Firefox)

Я изучил и изменил следующие настройки в Mozilla Firefox для повышения безопасности и конфиденциальности:

Усиленная защита от отслеживания (Strict Mode)

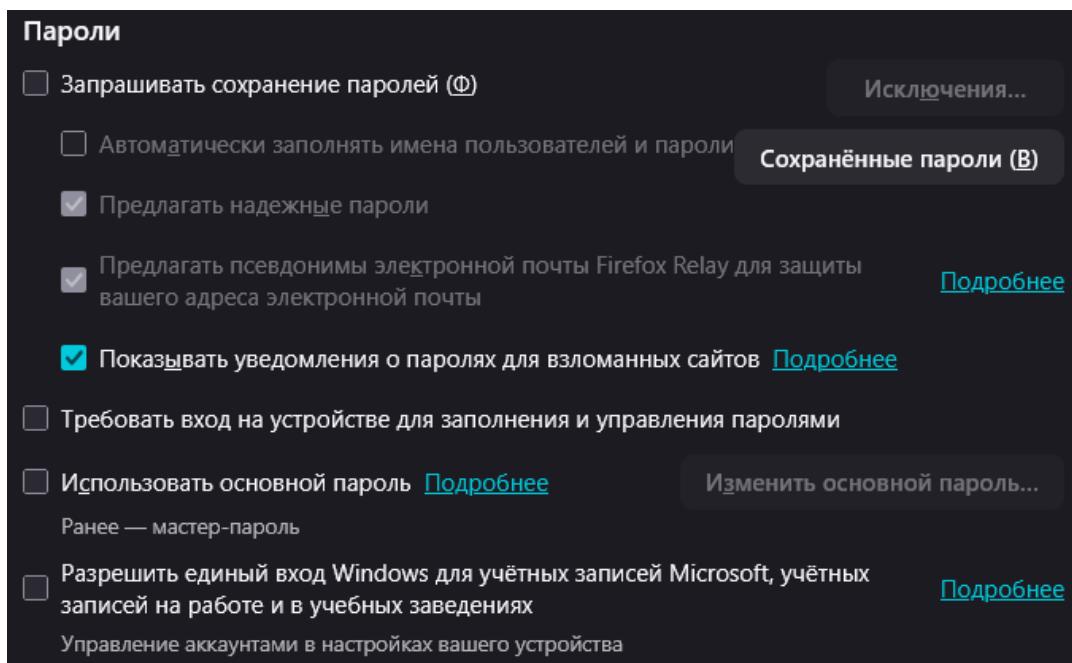
Я выставил строгую приватность браузера. Этот режим блокирует известные трекеры в приватных и обычных окнах, куки сторонних сайтов, криптомайнеры, "отпечатки" (fingerprints). Это наиболее агрессивный подход к защите данных в браузере



Тут же браузер сразу предупреждает, что при такой защите некоторые сайты могут не работать, страницы просто не загрузятся, в большинстве своём, из-за блокировки большинства треккингов и межсайтовых куки.

Отключение сохранения паролей

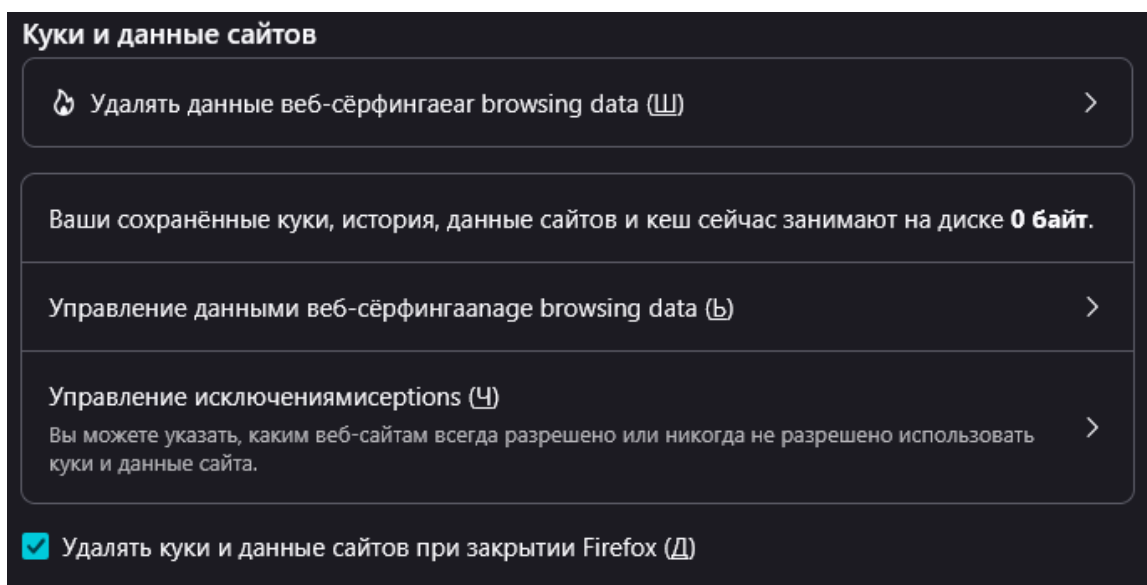
Для исключения риска компрометации сохраненных паролей в случае доступа к устройству или уязвимости в браузере. Я не хочу дополнительно делиться данными о паролях с браузером (хоть браузер и хранит их в зашифрованном виде), ведь я уже использую Bitwarden.



При этом, я оставил активными уведомления о паролях для взломанных сайтов. В данном случае, такой подход не противоречит остальным настройкам и приятно сочетается с использованием Bitwarden.

Очистка куки, кэша и других данных сайтов

Я очистил текущие данные и отметил, что не хочу сохранять какие-либо результаты активности в браузере. Да, теперь мне чаще придётся входить в аккаунты и так далее, но я точно уверен, что мои данные с большей вероятностью останутся при мне. В купе с Bitwarden проблем возникнуть не должно, разве страницы изначально будут дольше грузиться. Также, нужно будет привыкнуть закрывать браузер.



В остальном, я оставил настройки по умолчанию.

Защита

Поддельное содержимое и защита от вредоносных приложений

☒ Блокировать опасное и обманывающее содержимое (L) [Подробнее](#)

☒ Блокировать опасные загрузки (K)

☒ Предупреждать о нежелательных и редко загружаемых приложениях (X)

Сертификаты

Настроить сертификаты, которые Firefox использует для аутентификации. [Подробнее](#)

Просмотр сертификатов...ertificates... (M) >

Устройства защиты...evices... (I) >

☒ Разрешить Firefox автоматически доверять установленным вами сторонним корневым сертификатам. (E) [Подробнее](#)

Режим «Только HTTPS»

Разрешает только защищённые соединения с веб-сайтами. Firefox будет спрашивать перед незащищённым соединением. [Подробнее](#)

☐ Включить режим «Только HTTPS» во всех окнах

☐ Включить режим «Только HTTPS» только в частных окнах

☒ Не включать режим «Только HTTPS»
Firefox сможет всё ещё переключать некоторые соединения [Подробнее](#)

Управление исключениями...ceptions... (H) >

DNS через HTTPS

Система доменных имен (DNS) через HTTPS отправляет ваш запрос на доменное имя через зашифрованное соединение, обеспечивая безопасный DNS и мешая другим увидеть, к какому веб-сайту вы собираетесь получить доступ. [Подробнее](#)

Состояние: Off

Управление исключениями...

Включить DNS через HTTPS, используя:

☒ **Защиту по умолчанию**
Firefox решает, когда использовать безопасный DNS для защиты вашей конфиденциальности.

- Использовать безопасный DNS в регионах, где он доступен
- Использовать разрешение DNS по умолчанию, если имеется проблема с поставщиком безопасного DNS.
- Использовать местного поставщика, если это возможно [Подробнее](#)
- Отключить, когда активны VPN, родительский контроль или корпоративные политики.
- Отключить, когда сеть сообщает Firefox, что она не должна использовать безопасный DNS. [Подробнее](#)

☐ **Повышенную защиту**
Вы сами решаете, когда использовать безопасный DNS, и выбираете своего поставщика.

☐ **Максимальную защиту**
Firefox всегда будет использовать безопасный DNS. Вы увидите предупреждение об угрозе безопасности, прежде чем мы будем использовать DNS вашей системы.

☐ **Отключить**
Использовать разрешение DNS по умолчанию

Я не хочу ограничиваться конкретным поставщиком DNS или каждый раз выбирать, когда использовать или не использовать безопасный DNS. Режим

для https может мешать выполнению лаб, пока учусь, не буду менять этот параметр.

Анализ сетевого трафика на примере github.com

Я открыл инструменты разработчика, перешел на вкладку «Сеть» и обновил страницу github.com

В панели отобразился водопад (waterfall) всех HTTP/HTTPS-запросов, необходимых для загрузки страницы: HTML, CSS, JS, изображения, шрифты, API-вызовы.

The screenshot shows the Network tab of a web browser's developer tools. The waterfall chart displays various requests to github.com, including HTML, CSS, JS, and images. The status bar at the bottom indicates 188 requests, 9.13 MB / 546.15 kB transferred, and a load time of 3.17 s.

Статус	Метод	Домен	Файл	Инициатор	Тип	Состояние	Размер	Время	
200	GET	github.githubassets.com	copilot-chai-21a095e6c0f.js	chunk-6858-e18967b1723.js	script	кешировано	722.54 kB	0 мс	
200	GET	github.com	indicator	environment-e4509e0396a.js	font	кешировано	17.6	220 мс	
200	GET	github.githubassets.com	1650-9d026f8e309a45d0df.module.css	stylesheet	css	кешировано	286.6	0 мс	
200	GET	github.githubassets.com	16702-3073664aa7b20246d0df.module.css	stylesheet	css	кешировано	372.6	0 мс	
200	GET	github.githubassets.com	typebox-d4434d1099e.js	wp-runtime-6b183677763.js	script	кешировано	142.56 kB	0 мс	
200	GET	github.githubassets.com	99416-9d4961969d0d.js	wp-runtime-6b183677763.js	script	кешировано	21.41 kB	0 мс	
200	GET	github.githubassets.com	7169514d27676bca7c1634b3.module.css	stylesheet	css	кешировано	1.35 kB	0 мс	
200	GET	github.githubassets.com	30587-2892829152e.js	wp-runtime-6b183677763.js	script	кешировано	9.52 kB	0 мс	
200	GET	github.githubassets.com	33915-050a7b0edc31.js	wp-runtime-6b183677763.js	script	кешировано	6.50 kB	0 мс	
200	GET	github.githubassets.com	96537-8e29101f7d81.js	wp-runtime-6b183677763.js	script	кешировано	4.74 kB	0 мс	
200	GET	github.githubassets.com	34542-ad9de11f14341.js	wp-runtime-6b183677763.js	script	кешировано	8.26 kB	0 мс	
200	GET	github.githubassets.com	1311-2f168b0e5643.js	wp-runtime-6b183677763.js	script	кешировано	9.77 kB	0 мс	
200	GET	github.githubassets.com	30969-1d6b0da5d463.js	wp-runtime-6b183677763.js	script	кешировано	11.07 kB	0 мс	
200	GET	github.githubassets.com	5168-543d7770c2b.js	wp-runtime-6b183677763.js	script	кешировано	31.88 kB	0 мс	
200	GET	github.githubassets.com	92415-dad8ed3e1afe.js	wp-runtime-6b183677763.js	script	кешировано	67.60 kB	0 мс	
200	GET	github.githubassets.com	48739-2cc02b7731.js	wp-runtime-6b183677763.js	script	кешировано	36.28 kB	0 мс	
200	GET	github.githubassets.com	45555-811644464.js	wp-runtime-6b183677763.js	script	кешировано	14.96 kB	0 мс	
200	GET	github.githubassets.com	45961-2b2395e4d7f.js	wp-runtime-6b183677763.js	script	кешировано	21.19 kB	0 мс	
200	GET	github.githubassets.com	11524-5d9978f1e4c.js	wp-runtime-6b183677763.js	script	кешировано	14.56 kB	0 мс	
200	GET	github.githubassets.com	19046-7d6d92b002.js	wp-runtime-6b183677763.js	script	кешировано	10.71 kB	0 мс	
200	GET	github.githubassets.com	37906-b6573c5a22ba.js	wp-runtime-6b183677763.js	script	кешировано	26.77 kB	0 мс	
200	GET	github.githubassets.com	1459-c7a87e9f05b.js	wp-runtime-6b183677763.js	script	кешировано	15.39 kB	0 мс	
200	GET	github.githubassets.com	65426-07a3980ba04.js	wp-runtime-6b183677763.js	script	кешировано	13.45 kB	0 мс	
200	GET	github.githubassets.com	23390-4d36d164d00.js	wp-runtime-6b183677763.js	script	кешировано	10.81 kB	0 мс	
200	GET	github.githubassets.com	30061-a617468c1e03.js	wp-runtime-6b183677763.js	script	кешировано	21.44 kB	0 мс	
200	GET	github.githubassets.com	99753-a65a1f172669.js	wp-runtime-6b183677763.js	script	кешировано	47.76 kB	0 мс	
200	GET	github.githubassets.com	34722-28ba5e3b6f9e.js	wp-runtime-6b183677763.js	script	кешировано	18.13 kB	0 мс	
200	GET	github.com	chat?skip_anchor=true	environment-e4509e0396a.js	font	кешировано	5.58 kB	681 мс	
200	GET	github.githubassets.com	chunk-35011-e7375c78f90e.js	wp-runtime-6b183677763.js	script	кешировано	16.31 kB	4 мс	
200	GET	github.githubassets.com	favicon.png	img	NS_BINDING_ABORTED	0.6	0 мс	0 мс	
200	GET	github.githubassets.com	chunk-3403-400135689da.js	wp-runtime-6b183677763.js	script	кешировано	0.6	0 мс	0 мс
200	GET	github.githubassets.com	chunk-996-bfba72074490.js	wp-runtime-6b183677763.js	script	кешировано	0.6	0 мс	0 мс
200	GET	github.com	fluidicon.png	img	кешировано	33.27 kB	0 мс	0 мс	
200	GET	github.githubassets.com	favicon-dark.svg	img	svg	кешировано	957.6	0 мс	0 мс
200	POST	collector.github.com	collect	chunk-67295-33861e65d5e1.js	plain	NS_BINDING_ABORTED	0.6	167 мс	0 мс
200	POST	api.github.com	stats	environment-e4509e0396a.js	plain	NS_BINDING_ABORTED	3.65 kB	217 мс	0 мс
200	POST	collector.github.com	collect	chunk-67295-33861e65d5e1.js	plain	NS_BINDING_ABORTED	0.6	311 мс	0 мс
200	GET	github.githubassets.com	74667-f5c6418f46374dc58a2.module.css	stylesheet	css	кешировано	6.74 kB	0 мс	0 мс
200	POST	api.github.com	stats	environment-e4509e0396a.js	plain	NS_BINDING_ABORTED	2.27 kB	0 мс	182 мс

Рассмотрим один из первых запросов типа GET:

URL: <https://github.com/> - целевой адрес. Протокол HTTPS указывает на использование шифрованного соединения

Статус: 200 OK - запрос успешно выполнен, сервер отправил запрашиваемую страницу

Ключевые заголовки ответа (Response Headers):

Эти заголовки показывают, как сервер (github.com) инструктирует браузер:

content-type: text/html; charset=utf-8

Вывод: Сервер сообщает, что возвращает документ в формате HTML (веб-страницу) с кодировкой UTF-8. Это подтверждает, что данный запрос загрузил основную структуру сайта.

set-cookie: gh_sess=...

Вывод: Это один из самых важных заголовков для анализа безопасности и отслеживания. Сервер GitHub устанавливает в браузере пользователя сессионную куку с именем gh_sess. Эта кука:

Защищена флагами:

secure - передается только по HTTPS.

HttpOnly - недоступна для JavaScript (защита от XSS-атак).

SameSite=Lax - ограничивает отправку куки при межсайтовых запросах (защита от CSRF).

Назначение: Служит для идентификации пользовательской сессии. При последующих запросах браузер будет автоматически отправлять эту куку обратно на GitHub, чтобы сервер "узнал" пользователя (после входа в аккаунт).

Угроза конфиденциальности: Сама по себе эта кука (для домена github.com) не является трекером для отслеживания между сайтами. Однако она является инструментом идентификации пользователя на одном сайте.

strict-transport-security: max-age=31536000; includeSubDomains; preload

Вывод: Директива HSTS. Приказывает браузеру в течение года (31536000 секунд) автоматически подключаться к этому домену и всем его поддоменам только по HTTPS, даже если пользователь введет http://github.com. Это серьезное усиление безопасности, предотвращающее атаки downgrade.

content-security-policy: ...

Вывод: Сложная и детальная политика безопасности контента (CSP). Она строго ограничивает, откуда браузеру разрешено загружать скрипты, стили, изображения и другие ресурсы. Это мощный механизм защиты от внедрения вредоносного кода (XSS-атак).

x-frame-options: deny

Вывод: Запрещает браузерам встраивать страницу GitHub в <iframe> на других сайтах. Защита от атак типа "кликджекинг".

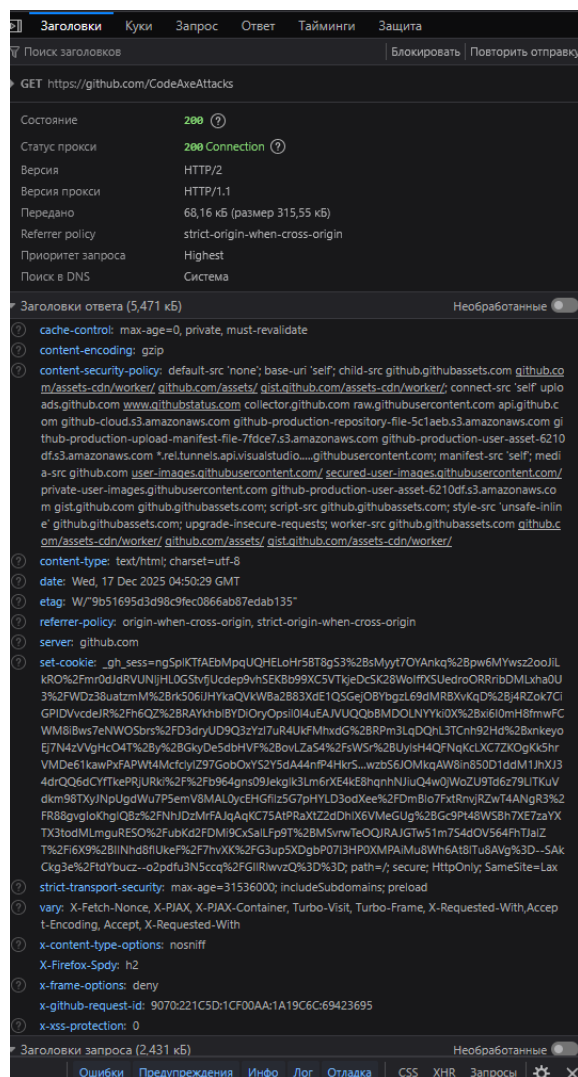
Заголовки запроса (Request Headers):

В предоставленном фрагменте они не раскрыты, но можно предположить, что туда входят:

User-Agent - информация о браузере и ОС.

Ассерт - типы контента, которые браузер готов принять

Cookie - если бы у пользователя уже была сохраненная кука от GitHub, она отправилась бы здесь. В данном случае, вероятно, это первый запрос, поэтому поле Cookie могло быть пустым



Важно учесть, что при закрытии браузера, учитывая его настройки, теперь очистятся куки.

Как чаще всего передаются данные аутентификации (логин/пароль) в современных веб-приложениях?

Рассмотрим форму входа github.com

Используется защищенное соединение (HTTPS/TLS)

Запрос отправляется на <https://github.com/session>

Сервер устанавливает политику HSTS (strict-transport-security), принудительно использующую HTTPS. Это гарантирует шифрование всех передаваемых данных на транспортном уровне

Применяется метод POST:

Для отправки данных формы используется HTTP-метод POST, который помещает логин и пароль в тело запроса (не в URL)

Реализованы дополнительные механизмы защиты:

CSRF-токен (authenticity_token) - предотвращает межсайтовую подделку запросов

Защищенные сессионные куки (gh_sess с флагами HttpOnly, Secure, SameSite=Lax)

Строгая политика CSP - ограничивает источники загрузки контента

Особенность отображения в инструментах разработчика:

В Firefox DevTools во вкладке "Параметры" пароль может отображаться в открытом виде

НО: Это показывает данные на этапе формирования запроса в браузере

Фактическая передача по сети происходит в зашифрованном виде благодаря HTTPS

Вывод: в современных веб-приложениях (как и на GitHub) логин и пароль передаются в зашифрованном виде на уровне транспортного протокола (HTTPS/TLS), при этом используются дополнительные меры безопасности (CSRF-токены, защищенные куки, CSP), что в совокупности обеспечивает безопасную аутентификацию.

ЗаголовкиКукиЗапросОтветТаймингиЗащита

Поиск в параметрах запроса

Данные формПоказать код

commit: "Sign+in"

authenticity_token: "0b7gUCvIQOfuhsW5+leSlv+sXkOJyywzKmyloeAhGJz0bLmzmyehT0XTMptjnZi2fco0kX5QmW9vkUBA/13Zng=="

add_account: ""

login: "test_account_github_analysis@example.com"

password: "TestPassword123!@#"

webauthn-conditional: "undefined"

javascript-support: "true"

webauthn-support: "supported"

webauthn-uvpaa-support: "unsupported"

return_to: "https://github.com/login"

allow_signup: ""

client_id: ""

integration: ""

required_field_f949: ""

timestamp: "1765949583583"

timestamp_secret: "8cdd273fcb43dfcb8aaecec83c137dad273384aeba89f74ef74095bf0e98ec0"

ЗаголовкиКукиЗапросОтветТаймингиЗащита

Поиск заголовковБлокироватьПовторить отправку

POST https://github.com/session

Состояние200

ВерсияHTTP/2

Передано16,63 кБ (размер 43,85 кБ)

Referrer policystrict-origin-when-cross-origin

Приоритет запросаHighest

Поиск в DNSСистема

Заголовки ответа (5,131 кБ)Необработанные

cache-control: max-age=0, private, must-revalidate

content-encoding: gzip

content-security-policy: default-src 'none'; base-uri 'self'; child-src github.githubassets.com githu...m/assets-cdn/worker/ github.com/assets/ gist.github.com/assets-cdn/worker/; connect-src 'self' uplo...ads.github.com www.githubstatus.com collector.github.com raw.githubusercontent.com api.github.c...om github-cloud.s3.amazonaws.com github-production-repository-file-5c1aeb.s3.amazonaws.com gi...thub-production-upload-manifest-file-7fdce7.s3.amazonaws.com github-production-user-asset-6210...df.s3.amazonaws.com *.rel.tunnels.api.visualstudio....githubusercontent.com; manifest-src 'self'; medi...a-src github.com user-images.githubusercontent.com/ secured-user-images.githubusercontent.com/...private-user-images.githubusercontent.com github-production-user-asset-6210df.s3.amazonaws.co...m gist.github.com github.githubassets.com; script-src github.githubassets.com; style-src 'unsafe-inlin...e' github.githubassets.com; upgrade-insecure-requests; worker-src github.githubassets.com githu...om/assets-cdn/worker/ github.com/assets/ gist.github.com/assets-cdn/worker/

content-type: text/html; charset=utf-8

date: Wed, 17 Dec 2025 05:38:47 GMT

etag: W/"4f7453840141ac2c35e31b06fb659c49"

referrer-policy: origin-when-cross-origin, strict-origin-when-cross-origin

server: github.com

set-cookie: _gh_sess=yQGgJ0hrr0J%2Fqd%2BnKrEYLPQH7HPq5%2BRiUudtew0fjai7Ddz9lWVtn35Qe1gLqYR4f0c8MLctk2yitMpqLs%2FU0MnlkvieVBA5v2N6jAJMgJNDmMCPjUYwIDSwMZ%2Fo24nnUGLsj...a6tskvWDMvkuUjg5XJi0TPWdDYOfP8SjMpDzRuc8i8Ledk3XWMjddel9C98nA0c26wdsqYvKTUfEVV4ek...kMQbn%2BKF4QZsg%2Fjd1gXB8yp3iCVBKA0ZAuLbU5eY6d9zj7wcqdn2h%2FBi769U8ITYjqtTfUdhGg...GgHLBJ8GXA2HWKUGn8h82PjzeMtaLu9mDWZMNaJ6CSzRKaoHgwrvVMk6jiaPLK2lZEVVMkhzzWvR...WcVUy3osAllwxCPDfHtGtlcc4ZvTPW6nzdjP5lmgTNh3VZzc0UzTUB8RP%2BgqUWHuF4UMx3pxyD76...XLG3t%2BfWQJZL75Vui0AxxYo0Z5lv8YcQmWhGloOhsUMIXBhNV58QVY4EiAagzYnRiBUjHiPh%2FTJl...szQUv8D0Cpf5o9vv76dB6ZwWuLVlvU6n98aGuuLiLfg81D0AphikKv2Lqw%2BuzNLWRfHmhWkHcwW...QLo84hj%2Bz7TyHdoeQSOYqeYCFgv9jSmEkn1RaSQYVaCIHfBoB3kZ0zEz5luXmd791Pw%2FeRrkjdg...5ValQzXWO4sIDtxWu1sHbPQGPd6fnllw96TGdEjzYi6jyx6Av41FANmBhbGdy4lqDV52Xy%2FPTGK2uRn...Wv4Enn41JjEhUhsF9wmWv06EpSF1DUaIODA%3D%3D...mtX0ipNRa2%2BTHfPv--jEyRE64qHyseYU0...ZwtPpw%3D%3D; path=/; secure; HttpOnly; SameSite=Lax

strict-transport-security: max-age=31536000; includeSubdomains; preload

vary: X-PJAX, X-PJAX-Container, Turbo-Visit, Turbo-Frame, X-Requested-With, Accept-Encoding, Acce...pt, X-Requested-With

x-content-type-options: nosniff

x-firefox-spdy: h2

x-frame-options: deny

x-github-request-id: F18C:F2AD8:206D4EC:1D04743:694241E5

x-xss-protection: 0

Заголовки запроса (1,653 кБ)Необработанные